

Cybersecurity Daily Newsletter

Vol. 005 | 2026-09-30 09:00 WIB

Top 5 Highlights

- Two former Air Force members sentenced for BEC scams and phishing
- Former IBM X-Force Red leaders launch AI-powered offensive cybersecurity startup
- Vietnamese national charged in \$16 million cryptocurrency pig butchering scam
- PhantomSub campaign uses 101 npm packages to add developers to WhatsApp groups
- Phishing Abuses RMM Tools for Persistent Access

Threat Intelligence (10)

01. Two former Air Force members sentenced for BEC scams and phishing

The duo stole victims' employee email credentials through spamming and phishing campaigns.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources:

<https://www.scworld.com/brief/two-former-air-force-members-sentenced-for-bec-scams-and-phishing>

02. Phishing Abuses RMM Tools for Persistent Access

Microsoft observed phishing campaigns that abused MSP360 RMM to deploy ScreenConnect, creating redundant remote-access channels for follow-on activity The post Phishing Abuses RMM Tools for Persistent Access appeared first on Microsoft Security Blog .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.microsoft.com/en-us/security/blog/2026/09/29/phishing-abuses-rmm-tools-persistent-access/>

03. Add one more AI worry to the nightmare scenario: self-replicating prompt injections

It's a worm attack, AI-style

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/09/29/add-one-more-ai-worry-to-the-nightmare-scenario-self-replicating-prompt-injections/5299922>

04. Custom ChatGPTs push ClickFix attacks to deploy RAT malware

Custom variants of OpenAI's ChatGPT promoted in sponsored Google results are directing unsuspecting users to malicious sites that use ClickFix attacks to deliver malware. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/custom-chatgpts-push-clickfix-attacks-to-deploy-rat-malware/>

05. Former US Air Force members sent to prison over BEC attacks

Two former members of the United States Air Force were sentenced to a combined 189 months in federal prison for their roles in a multi-year series of business email compromise (BEC) scams and phishing campaigns. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/former-us-air-force-members-sent-to-prison-over-bec-attacks/>

06. Russia's Star Blizzard Targets 100+ Organizations With Fake Event Invites to Deliver Backdoor

Russian state hackers known as Star Blizzard have been using fake event invitations to trick people into installing a backdoor on their Windows computers, according to Microsoft. The campaigns, aimed at people and organizations tied to Ukraine, have affected more than 100 organizations since January, mostly in the U.S. and U.K. At least one computer was inf...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/russias-star-blizzard-targets-100.html>

07. 'NeedyMantis' Provides Long-Term Access to Compromised Networks

Microsoft observed a China-based actor using a previously unidentified malware framework in targeted intrusions against telcos, universities, medical, and government-related organizations.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.darkreading.com/threat-intelligence/needymantis-long-term-access-compromised-networks>

08. Star Blizzard refines phishing and malware delivery with the RedFlick technique

Since January 2026, Microsoft has observed Russian state threat actor Star Blizzard evolve their detection evasion capabilities through large-scale phishing campaigns, the use of accounts on compromised websites, and a novel malware delivery technique, tracked by Microsoft as "RedFlick". The post Star Blizzard refines phishing and malware delivery with the...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.microsoft.com/en-us/security/blog/2026/09/29/star-blizzard-refines-phishing-and-malware-delivery-with-the-redflick-technique/>

09. RatHat's Evolving C2 Panel Points to Malware-as-a-Service Model

RatHat's C2 panel now builds malware and ranks victims with AI across nearly 100 deployments

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/rathat-c2-panel-malware-as-a/>

10. Microsoft Warns NeedyMantis Malware Enables Persistent Network Access

Microsoft Threat Intelligence warns that NeedyMantis threat actor from China has targeted organizations across a range of industries

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/microsoft-needymantis-malware/>

Latest Vulnerabilities (10)

01. Former IBM X-Force Red leaders launch AI-powered offensive cybersecurity startup

RemoteThreat's platform is designed to simulate nation-state level attacks for Fortune 500 organizations and provide government operators with tools to target adversaries at speed and scale.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/former-ibm-x-force-red-leaders-launch-ai-powered-offensive-cybersecurity-startup>

02. PhantomSub campaign uses 101 npm packages to add developers to WhatsApp groups

The malicious npm packages, collectively downloaded 490,000 times, exploit the "Baileys" WhatsApp open-source project to subscribe developers to various WhatsApp groups.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/phantomsub-campaign-uses-101-npm-packages-to-add-developers-to-whatsapp-groups>

03. Apple Zero-Day Vulnerability Weaponized in Targeted Attacks

Attackers are exploiting CVE-2026-86950, an out-of-bounds write flaw, in an extremely sophisticated fashion, according to Apple.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/apple-zero-day-vulnerability-weaponized-targeted-attacks>

04. Unsloth Studio Flaw Turns Routine Model Inspection Into Code Execution

A patched Unsloth Studio vulnerability allows malicious AI models to execute arbitrary Python code during inspection, via the `trust_remote_code` setting.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/application-security/unsloth-studio-flaw-model-inspection-code-execution>

05. 57% of security execs report challenges with onboarding entry-level staff

SkillBit survey says security teams struggle to find and train new staff as AI compresses the time they have to patch new bugs.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/news/57-of-security-execs-report-challenges-with-onboarding-new-staff>

06. Hackers exploit Citrix NetScaler zero-day to deploy web shells

Cybersecurity firms say attackers exploited the Citrix NetScaler CVE-2026-88772 zero-day to deploy custom web shells and tunneling malware, gain root access, steal credentials, and spread into internal networks. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/hackers-exploit-citrix-netscaler-zero-day-to-deploy-web-shells/>

07. Custom malware used in Citrix 0-day attacks targeting govt, banks, professional services

Two questions remain: who is abusing the CVEs? And why did Citrix take so long to disclose?

Why it matters: Publicly discussed 0-days often see rapid weaponization, increasing the risk of opportunistic attacks at scale.

Recommendation: Apply vendor guidance immediately, reduce attack surface, and monitor for IoCs/exploitation telemetry until patches are fully deployed.

Sources: <https://www.theregister.com/security/2026/09/29/custom-malware-used-in-citrix-0-day-attacks-targeting-govt-banks-professional-services/5299867>

08. New Spectre-v2 BTR Attack Leaks Linux Memory Despite Existing Defenses

A group of academics from VUsec and Scuola Superiore Sant'Anna have disclosed details of a new Spectre CPU vulnerability variant that affects Just-In-Time (JIT) engines present in web browsers, language runtimes, and the operating system kernel, across multiple CPU vendors. The new Spectre-v2 variant has been codenamed Branch Target Reuse (BTR).

"The key in...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/09/new-spectre-v2-btr-attack-leaks-linux.html>

09. Beyond source code: A path to the keys to the kingdom

Explore how Storm-3068 turned a compromised identity into broader cloud access and the steps organizations can take to defend their identities, pipelines, and cloud infrastructure. The post Beyond source code: A path to the keys to the kingdom appeared first on Microsoft Security Blog .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.microsoft.com/en-us/security/blog/2026/09/29/beyond-source-code-a-path-to-the-keys-to-the-kingdom/>

10. Automated AI agent used to breach cybersecurity nonprofit DIVD

The Dutch Institute for Vulnerability Disclosure (DIVD) suffered an AI-driven cyberattack that the organization described as "loud and very, very messy." [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/automated-ai-agent-used-to-breach-cybersecurity-nonprofit-divd/>

Data Breach & Cybercrime (10)

01. Vietnamese national charged in \$16 million cryptocurrency pig butchering scam

A Vietnamese national has been charged with money laundering for his alleged role in a massive "pig butchering" scam that defrauded a victim of \$16 million in cryptocurrency.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/vietnamese-national-charged-in-16-million-cryptocurrency-pig-butchering-scam>

02. FBI tells ShinyHunters members to turn themselves in after recent arrest

The FBI is warning members of the ShinyHunters extortion group to turn themselves in after Dutch police arrested a man the bureau described as one of the group's alleged leaders. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/fbi-tells-shinyhunters-members-to-turn-themselves-in-after-recent-arrest/>

03. French Tax Data Theft Using Stolen Staff Passwords Went Undetected for Seven Weeks

An attacker used stolen passwords of staff at France's tax administration to take tax data on hundreds of thousands of taxpayers and businesses in June and July. Neither the tax administration nor France's national cybersecurity agency saw the data leave. The attack was not sophisticated, the agency, ANSSI, says in a report (in French) published on Tuesday:...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/09/french-tax-data-theft-using-stolen.html>

04. New Spectre v2 attack variant leaks Linux root password hash in minutes

A new Branch Target Reuse (BTR) attack has been devised that can recover root password hashes on Intel computers running Linux in 3-5 minutes on average. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/new-spectre-v2-attack-variant-leaks-linux-root-password-hash-in-minutes/>

05. New Spectre v2 Variant Exposes Intel, AMD, Arm CPUs to Data Leaks

Branch Target Reuse (BTR) is a new Spectre v2 attack targeting JIT compilers in web browsers, language runtimes, and the operating system kernel The post New Spectre v2 Variant Exposes Intel, AMD, Arm CPUs to Data Leaks appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.securityweek.com/new-spectre-v2-variant-exposes-intel-amd-arm-cpus-to-data-leaks/>

06. Pentagon Personnel Agency Data Breach Impacts 3 Million People

The data breach affects the Defense Manpower Data Center (DMDC), which maintains personnel records for the Department of Defense. The post Pentagon Personnel Agency Data Breach Impacts 3 Million People appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.securityweek.com/pentagon-personnel-agency-data-breach-impacts-3-million-people/>

07. Vietnamese man charged in \$16 million 'pig butchering' crypto scam

A Vietnamese national was charged with money laundering for his role in a massive "pig butchering" scam, which defrauded a victim out of \$16 million worth of cryptocurrency. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/vietnamese-man-charged-in-16-million-pig-butchering-crypto-scam/>

08. [+24h Old] Fake iPhone Duo preorder scam triggers DarkSword attack

A fake iPhone Duo preorder page promises a \$500 voucher. Open it on a vulnerable iPhone, and it tries to break in before you fill out the form.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/threat-intel/2026/09/fake-iphone-duo-preorder-scam-triggers-darksword-attack>

09. [+24h Old] Dutch Police Arrest 24-Year-Old Amsterdam Man in ShinyHunters Investigation

Dutch authorities have confirmed that they arrested a 24-year-old man from Amsterdam in connection with the ShinyHunters group. "It is true that this month a 24-year-old man from Amsterdam was arrested in an investigation into the hacker group ShinyHunters," the Politie Landelijke Opsporing en Interventies said in an X post Monday. Police said the individua...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/09/dutch-police-arrest-24-year-old.html>

10. [+24h Old] Major Cyber Attacks in September 2026: US and EU Face Session Theft, Remote Access, and Payment Fraud

Cyberattacks observed in September showed how difficult it has become to separate malicious activity from legitimate business workflows. Attackers used trusted cloud services, familiar document-sharing platforms, legitimate authentication flows, remote-management software, and rapidly changing infrastructure to hide different stages of their operations. For...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://any.run/cybersecurity-blog/major-cyber-attacks-september-2026/>